



Design and Implementation of a Secure Core Banking System (SCBS)

Deliverable-I

Muhmmad Ismail	2023452
Ali Ahmed Chaudhry	2023093
Shayan Siddiqui	2023656

1. Security Requirements & Planning:

Security requirements define the security controls and mechanisms that must be implemented in the Secure Core Banking System (SCBS) to protect sensitive financial data and ensure secure system operations. These requirements are categorized into functional security requirements and non-functional security requirements.

1.1 Functional Security Requirements

Functional security requirements specify the security features that must be implemented within the system to protect user accounts, financial transactions, and system resources.

1.1.1 User Authentication

The system shall enforce secure user authentication using a username and password mechanism. User passwords must be stored using secure hashing with salt to prevent password disclosure in the event of a database compromise.

1.1.2 Multi-Factor Authentication (MFA)

The system shall support multi-factor authentication (MFA) by requiring an additional verification factor such as a One-Time Password (OTP) for sensitive operations, including fund transfers or account changes.

1.1.3 Authorization and Access Control

The system shall implement Role-Based Access Control (RBAC) to restrict system actions based on user roles (e.g., customer, administrator, manager). Each role will have predefined permissions that limit access to authorized resources only.

1.1.4 Transaction Integrity

The system shall ensure that all financial transactions are validated and processed securely to prevent unauthorized modification or manipulation of financial records.

1.1.5 Secure Session Management

The system shall maintain secure user sessions using secure session cookies and enforce automatic session expiration after a defined period of inactivity to prevent session hijacking.

1.2 Non-Functional Security Requirements

Non-functional security requirements define the security properties and system-wide protections that ensure secure system operation.

1.2.1 Secure Communication

All communication between system components shall be encrypted using Transport Layer Security (TLS) to protect data during transmission.

1.2.2 Secure Credential Storage

User credentials shall be stored using secure hashing algorithms such as bcrypt or SHA-256 with salt to protect against password disclosure and offline attacks.

1.2.3 Security Logging and Monitoring

The system shall record all login attempts, financial transactions, and critical system activities in secure audit logs to support monitoring and incident investigation.

1.2.4 Protection Against Common Web Attacks

The system shall implement security controls to protect against common web application attacks, including:

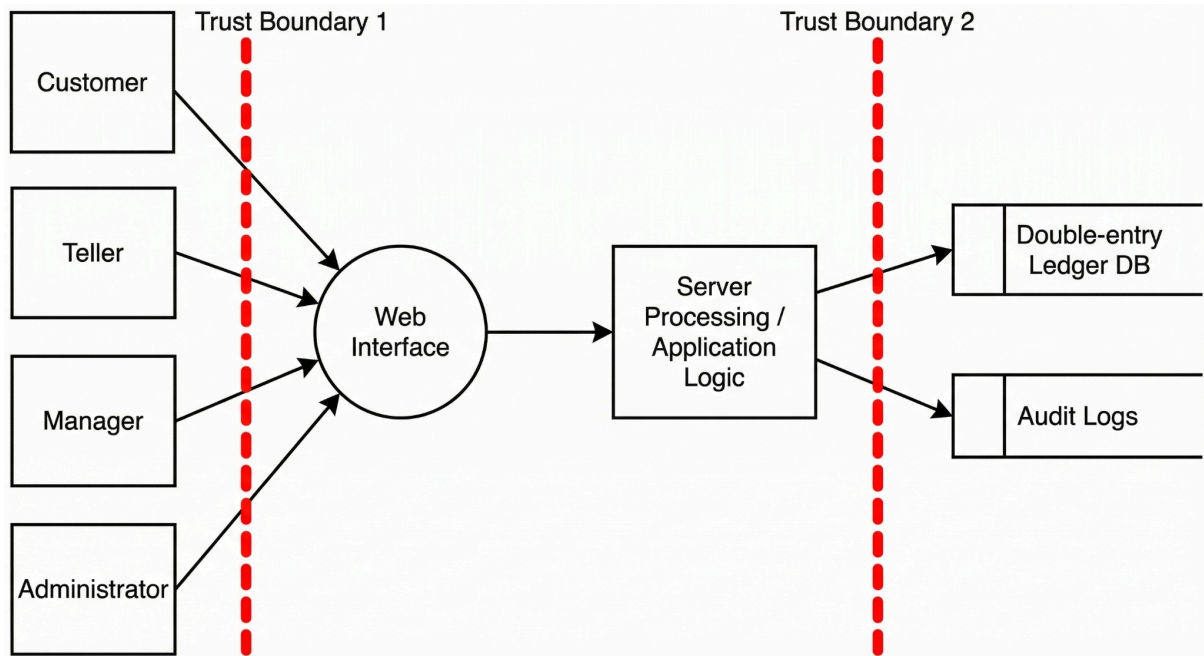
- SQL Injection through input validation and parameterized queries
- Cross-Site Scripting (XSS) through input sanitization and output encoding
- Brute-Force Attacks through rate limiting and account lockout mechanisms

2. Risk Management:

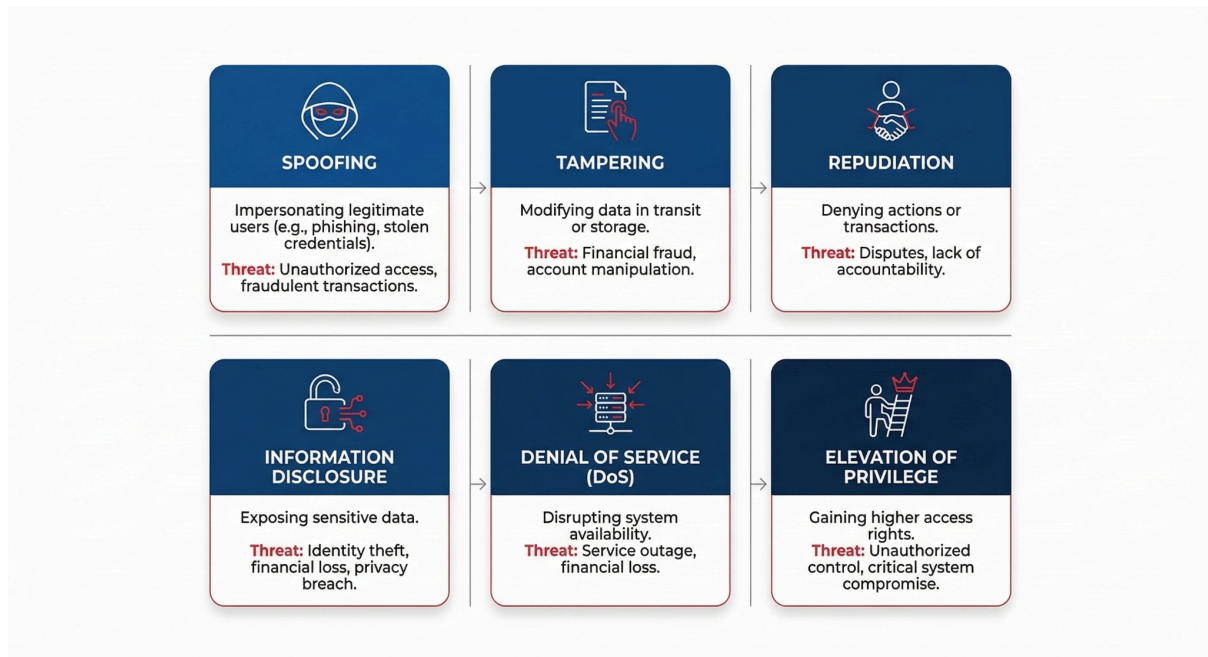
Risk	Description	Impact	Mitigation
Unauthorized Access	Attacker obtains valid user credentials	Account compromise	MFA + strong password policy
SQL Injection	Malicious SQL queries manipulate database	Data theft or modification	Input validation + prepared statements
Cross-Site Scripting (XSS)	Malicious scripts injected into web pages	Session hijacking or data theft	Input sanitization + output encoding
Brute Force Attack	Automated repeated login attempts	Account takeover	Rate limiting + account lockout
Data Interception	Sensitive data captured during transmission	Exposure of credentials or transactions	TLS encryption
Replay Attack	Attacker resends captured transaction packets	Duplicate or fraudulent transactions	Nonces + timestamps + session tokens
Data Tampering	Unauthorized modification of transaction data	Financial integrity loss	Transaction verification + database integrity checks
Privilege Escalation	User gains higher privileges (e.g., admin)	Full system compromise	Role-Based Access Control (RBAC)
Insider Threat	Authorized employee abuses privileges	Data manipulation or fraud	Access monitoring + audit logs

3. Threat Modeling:

Threat modeling for the SCBS will be conducted using the STRIDE framework alongside Data Flow Diagrams to identify trust boundaries and attack surfaces. To secure the system effectively, trust boundaries will be explicitly defined between client input, server processing, and database operations.



4. Threat Identification (STRIDE):



Spoofing: Attackers attempting to impersonate legitimate users are mitigated through Multi-factor authentication (OTP simulation) and secure session handling.

Tampering: The risk of data tampering is countered using HMAC validation, atomic transactions, and a double-entry ledger accounting model.

Repudiation: The system prevents users from denying actions by utilizing hash-chained audit logs and tamper-evident logging.

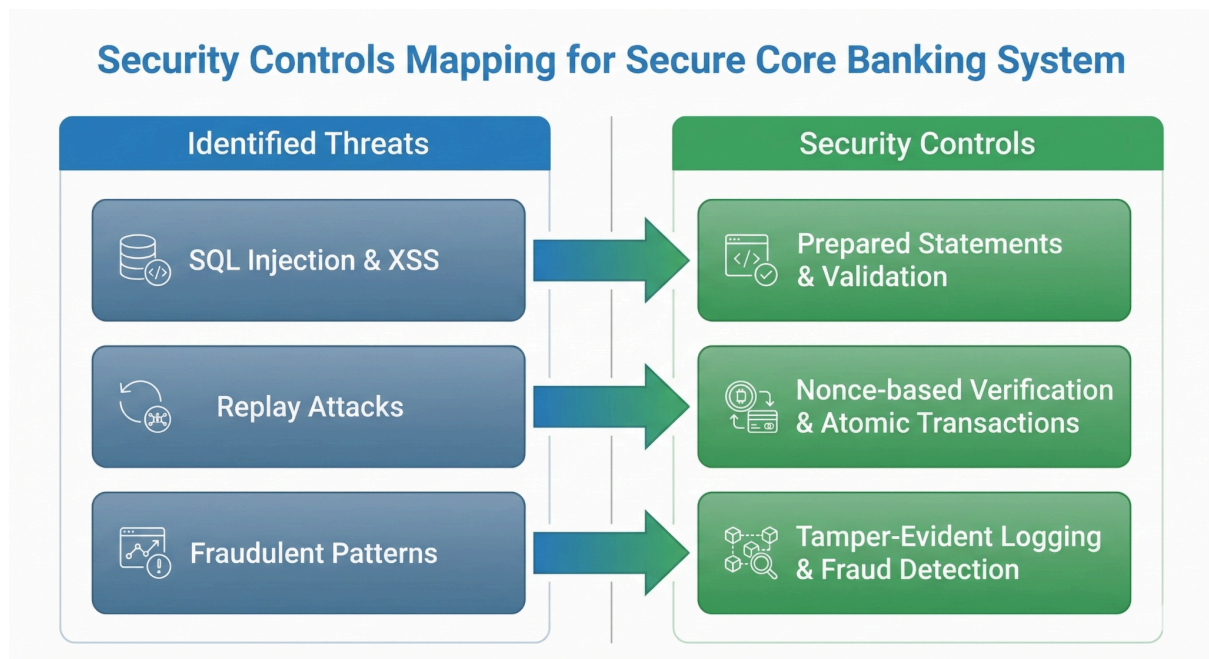
Information Disclosure: Confidential data exposure is prevented via secure password hashing (bcrypt/Argon2) and protected communication.

Denial of Service (DoS): Threats aiming to disrupt availability, such as brute-force attempts, are managed through rate limiting and account lockout mechanisms.

Elevation of Privilege: Privilege escalation attacks are mitigated by enforcing strict server-side Role-Based Access Control (RBAC).

5. Security Controls:

Security controls will be mapped directly to identified threats to ensure a comprehensive defense.



Input & Query Validation: Threats like SQL injection and XSS will be mitigated through the use of prepared statements and strict validation. All sensitive actions will be validated strictly server-side.

Transaction Security: Replay attacks will be countered with nonce-based request verification. Transfers will be processed using atomic database transactions for consistency.

Monitoring & Auditing: The system will utilize tamper-evident logging for auditing. Additionally, a rule-based fraud detection mechanism will flag abnormal or high-risk transaction patterns